Setnayan — Data Breach / Security Incident Management Policy

> **ADOPTION-READY · 2026-07-24.**

> [OK] **ADOPTION POSTURE — adopt now, counsel later.** This policy is prepared for the DPO to **adopt as v1.0 now**, on the DPO's own authority. To adopt: the owner supplies the fields in the checklist below, signs the § 11 approval block, and sets the effectivity date. **External PH counsel review is recommended, not blocking** — it is not required to adopt this policy; where counsel or the NPC later requires a change, it is applied by a **dated amendment**. Note: the 72-hour NPC + affected-data-subject breach-notification duty applies from adoption regardless of counsel status.

> This policy is issued under the Data Privacy Act of 2012 (Republic Act No. 10173, "**RA 10173**"), its Implementing Rules and Regulations (IRR), and **NPC Circular No. 16-03 (Personal Data Breach Management)**. It sets out how SETNAYAN SOFTWARE DEVELOPMENT SERVICE prevents, detects, assesses, contains, and reports personal data breaches and security incidents.

Field	Detail
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name No. 8297508. Brand: **Setnayan**.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · **dpo@setnayan.com** (updated 2026-10-22 — published contact per owner ruling 2026-09-22)
Document owner	Data Protection Officer
Version / date	ADOPTION-READY · 2026-07-24 · **Revised 2026-10-22 (v1.1) — the DPO re-signs § 11**
What changed in v1.1	Processor list (§ 1.2) rebuilt from the code — PostHog removed, identity-verification providers struck, Sentry/Anthropic/OpenAI/LanguageTool/Google/Apple added · monitoring (§ 3.2, § 4.1) limited to what exists (Sentry, Vercel/Supabase logs) — PostHog and Better Stack are not in the code · § 6.2 guest notification channel flagged (guests get no e-mail since 2026-09-29) · § 8.1 states that no breach register exists in the product yet · DPO contact → dpo@setnayan.com. See `00_WHAT_CHANGED_2026-10-22.md`.
Review cadence	At least annually, and after any notifiable breach
Legal basis	RA 10173 §§ 20, 26–31; IRR Rule VIII (Security Measures); Rule IX (Security Incidents & Breaches); **NPC Circular 16-03**

(!) Fields the owner must supply before signing

This policy is complete except for the following facts, which only the owner can provide. Each appears inline in the text as a bold **‹OWNER TO SUPPLY: …›** token. Supply all of them, then the DPO may sign.

1. **Breach-response hotline / 24-7 escalation contact** — a **single mobile number suffices to start** (the § 2.1 "DBRT contacts" line and the § 6.2 high-severity hotline both reference it): **‹OWNER TO SUPPLY: one mobile number›**
2. **Adoption / effectivity date** — the date this policy takes effect once the owner fields are supplied and the DPO signs (header + § 11 approval block): **‹OWNER TO SUPPLY: adoption date›**
3. **Technical / Engineering Lead** — name/holder for the § 2.1 DBRT role (was `[TO CONFIRM]` in the draft; no confirmed value provided): **‹OWNER TO SUPPLY: Technical/Engineering Lead holder›**
4. **Security / Operations Coordinator** — name/holder for the § 2.1 DBRT role (was `[TO CONFIRM]` in the draft; no confirmed value provided): **‹OWNER TO SUPPLY: Security/Operations Coordinator holder›**
5. **Communications / Legal liaison** — external PH counsel liaison, added when engaged (was `[TO CONFIRM]` in the draft; not yet engaged): **‹OWNER TO SUPPLY: external PH counsel liaison, once engaged›**

> Note: pending items 3–5 do not prevent the DBRT from operating — under § 2, in a 2-person founding team these responsibilities currently rest with the DPO and the supporting co-founder until the roles are formally filled or counsel is engaged.

---

1. Purpose & Scope

1.1 Purpose

This policy establishes Setnayan's mandatory procedure for managing **security incidents** and **personal data breaches** so that the PIC can:

- prevent breaches through documented organizational, physical, and technical measures;
- detect and assess incidents promptly and consistently;
- **notify the National Privacy Commission (NPC) and affected data subjects within 72 hours** where the breach is notifiable;
- contain, eradicate, and recover from incidents while preserving evidence; and
- maintain records and continuously improve through post-incident review.

1.2 Scope

This policy applies to **all** personal data processed by Setnayan across every processing system, whether stored, transmitted, or handled by:

- Setnayan personnel (the sole proprietor, the DPO, any engaged contractors / team members);
- Setnayan's processing systems — the Next.js web application, admin console, and databases; and
- Setnayan's **sub-processors / personal information processors** — Supabase, Vercel, Cloudflare (R2, relay, bot check), Resend, Sentry, Anthropic, OpenAI, LanguageTool, Google, Apple, Meta, TikTok and the others in Privacy Manual § 8.2 (rebuilt 2026-10-22). (!) Corrected 2026-10-22: Persona / Veriff / Onfido struck — retired 2026-07-03, never engaged; PostHog struck — removed 2026-10-22.

It covers customer (couple/organizer), vendor, and guest personal data, including **sensitive personal information** and the special category of **face vectors** described in the Privacy & Security Policy § 1.

1.3 Definitions

Term	Meaning (per NPC Circular 16-03 & RA 10173 IRR)

Security incident	An event or occurrence that **affects or tends to affect** data protection, or may compromise the availability, integrity, or confidentiality of personal data. Includes incidents that would result in a personal data breach if not for safeguards that were in place. **All** security incidents are logged; not all are breaches.
Personal data breach	A breach of security leading to the **accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to** personal data transmitted, stored, or otherwise processed.
Availability breach	Loss, accidental or unlawful destruction, or **loss of access** to personal data (e.g. R2/Supabase outage causing data loss; ransomware locking records).
Integrity breach	**Unauthorized or accidental alteration** of personal data (e.g. tampered records, corrupted face-vector store, malicious edits via a compromised admin account).
Confidentiality breach	**Unauthorized or accidental disclosure of, or access to,** personal data (e.g. leaked credentials, an RLS bypass exposing another user's rows, a mis-issued signed URL).
Sensitive personal information (SPI)	As defined in RA 10173 § 3(l) — includes government-issued IDs, and, for Setnayan, **face vectors / biometric data** and vendor government-ID images.
Notifiable breach	A personal data breach meeting **all** the criteria in § 5.2 (SPI or identity-fraud-enabling data, AND real risk of serious harm).
DBRT	Data Breach Response Team (§ 2).
NPC	National Privacy Commission.

2. Data Breach Response Team (DBRT)

Per NPC Circular 16-03 § 5, the PIC constitutes a Data Breach Response Team responsible for the entire incident lifecycle. Setnayan is a sole proprietorship operated by a **2-person founding team**. The breach-response structure is: the **DPO — Indalecio Sacdalan Casasola II (proprietor) — leads**, and **Claire E. Buanhog (VP, co-founder) supports**. There are **no external DBRT members yet**; an **external PH counsel liaison is added when engaged**. Roles may be held by the same individual or by engaged contractors, but each **responsibility** below is assigned and accountable.

2.1 Composition & roles

Role	Held by	Core responsibilities
DBRT Lead / Data Protection Officer	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com	Overall accountability; convenes the DBRT; makes the notifiability determination (§ 5); signs and files NPC and data-subject notifications; primary NPC liaison.

PIC / Business Owner	Indalecio Sacdalan Casasola II (SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	Ultimate PIC accountability under RA 10173; approves external communications and remediation spend; authorizes sub-processor escalation.
DBRT Support / Co-founder	Claire E. Buanhog · VP, co-founder	Supports the DPO across the incident lifecycle; secondary point of contact; assists with triage, breach-register upkeep, and data-subject communications.
Technical / Engineering Lead	**‹OWNER TO SUPPLY: Technical/Engineering Lead holder›**	Detection, containment, eradication, recovery; evidence preservation; forensic timeline; coordination with Vercel/Supabase/Cloudflare support.
Security / Operations Coordinator	**‹OWNER TO SUPPLY: Security/Operations Coordinator holder›**	Monitors Sentry alerts and Vercel / Supabase logs (corrected 2026-10-22 — PostHog removed; Better Stack is not in the code — confirm whether any external uptime monitor is in use); triages user-reported incidents; maintains the breach register; runs the annual drill.
Communications / Legal liaison	**‹OWNER TO SUPPLY: external PH counsel liaison, once engaged›**	Drafts data-subject notifications and the public `setnayan.com/security` disclosure; legal review of NPC filings; media handling if applicable.

DBRT contacts (24/7 escalation): high-severity hotline — **‹OWNER TO SUPPLY: one mobile number›** (a single mobile number suffices to start); escalation email — iscasasolaii@gmail.com.

2.2 Activation & operation

- **Any** Setnayan person or sub-processor notification that suggests a possible breach must be reported to the DPO **and** the Security/Operations Coordinator **immediately** (target: within 1 hour of discovery).
- The DPO convenes the DBRT upon any credible report. The "72-hour clock" begins on **knowledge** of a personal data breach (see § 5.1), not on convening the team — so the DBRT is convened without delay.
- The DBRT operates against the quick-flow in § 10 and documents every step in the breach register (§ 8).

---

3. Prevention & Preparedness

Setnayan reduces breach likelihood and impact through the organizational, physical, and technical measures below — the operative controls are set out in the **Privacy & Security Policy §§ 5 and 7** and summarized here.

3.1 Technical measures (in place)

Control	Implementation
Deny-by-default access (RLS)	All Postgres queries gate through Supabase **Row-Level Security**; no client can read another user's row (Privacy Policy § 5.3). Canonical deny-by-default RLS patterns; RLS enabled at table-creation time.

Encryption in transit	**TLS 1.3** on all external connections and WebSocket channels; HSTS enabled; mixed-content blocked (§ 7.2).
Encryption at rest	**AES-256** on Supabase Postgres and Cloudflare R2; keys managed by Supabase/Cloudflare KMS. Face vectors stored in a per-event **encrypted** vector index (§ 7.1, § 1.4).
Least-privilege access	Production DB access restricted to designated roles; granular admin roles; **two-admin approval** for high-risk actions (role provisioning, refunds/grants > PHP 10K); signed URLs for media are short-lived (5 min for sensitive media) (§ 5.3).
Strong authentication	bcrypt-hashed passwords; OTP/SSO options; **TOTP 2FA mandatory for all admin roles** (§ 5.1).
Append-only audit log	Every admin action logged with timestamp, actor, action, target, before/after state, rationale; **no UPDATE permission**; export restricted (§ 5.4).
Application hardening	Input validation (zod), parameterized queries, React escaping + CSP, CSRF tokens, rate limiting on auth endpoints (§ 7.3).
Encrypted backups	**NONE — no automated database backups exist.** (!) CORRECTED 2026-08-17: this row declared "Daily encrypted Postgres backups retained 30 days (§ 7.1)" and the recovery step below relied on it. The database is on the FREE plan (no scheduled snapshots) and there is no backup job of our own. Owner ruling 2026-08-10 accepts this knowingly, to revisit before launch. **A recovery plan that points at backups we do not hold is worse than no plan** — see the corrected recovery step.

3.2 Monitoring & observability (in place)

- **Sentry** — application error and exception monitoring; anomalous error spikes surface potential incidents.
- **Better Stack** — uptime, heartbeat, and on-call alerting; drives availability-breach detection and the status page.
- ~~**PostHog**~~ — (!) CORRECTED 2026-10-22: **removed** (PR #6774); there is no product-analytics stream. Admin site **Visits** (daily aggregates, ROPA DPS-21) and the admin App Performance page can show unusual traffic.
- Vercel platform logs; Supabase logs and advisors; Cloudflare R2 access is signed-URL-only (no public reads).

3.3 Organizational measures

- This policy plus the Privacy & Security Policy are the standing breach-management framework.
- **Staff awareness:** every person with data access reads this policy on onboarding and at each annual review; the DBRT runs at least one **table-top breach drill per year**.
- **Sub-processor controls:** all sub-processors are bound by DPAs / SCCs; the Anthropic Console workspace runs zero-retention mode where configured. (!) CORRECTED 2026-10-22: **no DPA/SCC is signed with any processor yet** (task `t2-8`), and the Persona/Veriff/Onfido + AMLC line is struck (retired 2026-07-03).
- **Regular review:** this policy, access lists, and the sub-processor register are reviewed at least annually and after any notifiable breach (§ 9).

---

4. Detection & Assessment

4.1 How incidents are detected

1. **Automated monitoring / alerts** — Sentry error spikes, Supabase advisors, auth rate-limit triggers, the admin App Performance / Visits pages. (Corrected 2026-10-22 — PostHog removed; Better Stack not found in code.)
2. **User / data-subject reports** — a customer, vendor, or guest reports suspicious activity or exposure via iscasasolaii@gmail.com or in-app support (0029 Help Center ticket).
3. **Sub-processor notifications** — Vercel, Supabase, Cloudflare, Resend, Sentry, Anthropic, OpenAI, Google or Apple notifies Setnayan of a security event affecting Setnayan data. Setnayan's knowledge for the 72-hour clock arises when it receives such notice with sufficient detail (see § 5.1).
4. **Internal discovery** — a team member or contractor identifies a misconfiguration, leaked credential, RLS gap, or anomalous audit-log entry.

4.2 Initial triage (within 24 hours of discovery)

The Security/Operations Coordinator (or DPO) opens a breach-register entry and records:

- what happened, when discovered, how discovered, systems involved;
- whether **personal data** is involved (if not → security incident only, log and monitor);
- **categories of data** involved (ordinary PII, SPI, face vectors, credentials, financial receipts);
- estimated **number and categories of affected data subjects**; and
- whether the incident is ongoing or contained.

4.3 Severity & notifiability assessment

The DPO assesses severity and applies the notifiability test in § 5.2. If any input is unknown, the DBRT treats the breach as **potentially notifiable** and proceeds toward the 72-hour deadline while facts are confirmed, rather than delaying the clock.

---

5. The 72-Hour Rule

5.1 When the clock starts

The **72-hour** period runs from the time Setnayan has **knowledge of, or a reasonable belief that,** a **notifiable personal data breach** has occurred. Knowledge is presumed once the DPO or DBRT has sufficient information to conclude the § 5.2 criteria are (or are likely) met — including on receipt of a sub-processor's breach notice with adequate detail. Setnayan does **not** wait for full forensic certainty before notifying; it notifies within 72 hours and supplements the report as facts develop.

5.2 Notification criteria (all must be present)

Per RA 10173 § 20(f) and NPC Circular 16-03 § 11, notification of the NPC and affected data subjects is **mandatory** when **all three** of the following are met:

1. **There is a personal data breach** (confidentiality, integrity, or availability); **AND**
2. The personal data involved is either **(a) sensitive personal information** — for Setnayan this includes government-issued IDs, **face vectors / biometric data**, and vendor gov-ID images — **OR (b) any other information that may be used to enable identity fraud** (e.g. full name + email + credentials, payment-reference data, partial financial details); **AND**

3. There is a **real risk of serious harm** to the affected data subjects (e.g. identity theft, financial loss, fraud, reputational harm, discrimination, or unauthorized use of biometric identity).

If **any** criterion is absent, the breach is logged in the register (§ 8) and monitored, but NPC/data-subject notification is not mandatory — though Setnayan may still notify voluntarily where prudent. The DPO documents the reasoning either way.

5.3 What must happen within 72 hours

- **Notify the NPC** (§ 6.1) — file the breach notification with the NPC.
- **Notify affected data subjects** (§ 6.2) — in-app + email, per the required content.

Where notification within 72 hours is not feasible, Setnayan may, in **exceptional cases**, request that the NPC allow a delay or a phased notification, giving reasons; and it may postpone data-subject notification **only** to the extent, and for the period, the NPC directs or law-enforcement necessity requires. Any such deviation is documented and approved by the DPO with counsel.

---

6. Notification Content & Channels

6.1 NPC notification

Channel: filed with the National Privacy Commission via the NPC's prescribed breach-notification means (email / NPC portal as then in force), signed by the DPO.

Contents (NPC Circular 16-03 § 12):

1. **Nature of the breach** — a description of how and when it occurred and the type of breach (availability/integrity/confidentiality).
2. **Personal data possibly involved** — the categories and approximate number of data subjects and records affected (including whether SPI / face vectors).
3. **Measures taken** — actions taken or proposed to address the breach, to secure or recover the data, and to mitigate possible harm; and measures to prevent recurrence.
4. **Name and contact details of the DPO** or other accountable person from whom the NPC can obtain further information.

A **preliminary** notification may be filed within 72 hours with available facts, followed by supplemental submissions as the investigation completes.

6.2 Data-subject notification

Channels: primary — **in-app notice + email (via Resend)** to each affected data subject; a summary disclosure may also be posted on the site where appropriate (a public summary within **7 days** where appropriate). (!) **Updated 2026-10-22:** (1) no `setnayan.com/security` page exists yet — publish the summary on `/privacy` or a new page at the time; (2) **guests receive no e-mail since 2026-09-29** (owner: *"No email. Either use the qr and link only"*) and the RSVP no longer collects one, so for many guests the reachable channels are the in-app notice on their invitation page and the couple. **DPO decision needed:** confirm that a breach notice is an exception to the no-guest-e-mail rule where an e-mail is on file. Where individual notice is not reasonably possible, the DPO will use a substitute means (e.g. prominent public notice) as the NPC allows.

Contents (must be written in clear, plain language):

1. A description of the **nature of the breach** and the **personal data** possibly involved.
2. **Measures taken** by Setnayan to address the breach.

3. **Measures the data subject may take** to reduce risk (e.g. change password, monitor bank/e-wallet activity, revoke face data via the "Delete my face data" link).

4. **DPO contact** — iscasasolaii@gmail.com (and severity-high hotline **‹OWNER TO SUPPLY: one mobile number›**) for questions and assistance.

---

7. Containment, Eradication & Recovery; Evidence Preservation

7.1 Containment (immediate)

- Isolate affected systems / revoke compromised credentials, tokens, and signed URLs; rotate keys and secrets.
- Disable or lock affected accounts; force re-authentication where credentials may be exposed.
- Engage sub-processor support (Vercel / Supabase / Cloudflare / Resend) to halt ongoing exposure.
- Where an RLS/authorization gap is implicated, deploy an emergency policy fix or take the affected surface offline.

7.2 Eradication

- Remove the root cause — patch the vulnerability, correct the misconfiguration, revoke unauthorized access, remove malicious artifacts.
- Verify no persistence (backdoors, residual tokens, altered RLS policies, injected data).

7.3 Recovery

- (!) **THERE ARE NO BACKUPS TO RESTORE FROM (corrected 2026-08-17).** Recovery from a data-loss event is therefore limited to: the couple's own Google Drive copies of their originals (the only customer-held copy), media objects still present in object storage (a separate system, unaffected by a database loss), and manual reconstruction from application logs. **Restoring the database is NOT currently possible.** Re-establishing a backup capability is an owner decision recorded 2026-08-10 and deferred; until it lands, treat database loss as unrecoverable and prioritise prevention. Validate integrity against the audit log before returning to production.
- Monitor closely post-recovery (heightened Sentry/Better Stack watch) for recurrence.

7.4 Evidence preservation

- **Preserve, do not destroy.** Capture and retain logs, timestamps, audit-log excerpts (append-only), Sentry events, access records, sub-processor notices, and system snapshots relevant to the incident **before** remediation alters state where feasible.
- Maintain a chain-of-custody note in the register entry. Evidence supports NPC filings, potential law-enforcement referral, and post-incident review.

---

8. Documentation & Record-Keeping

8.1 Breach register (mandatory)

Setnayan maintains a **breach register** recording **all** security incidents and personal data breaches — notifiable or not — per NPC Circular 16-03 § 14. The register is maintained by the Security/Operations Coordinator under DPO oversight and stored access-restricted. Template in § 10. (!) **Status 2026-10-22: no breach register exists in the product yet** — the only home today is the free-text breach-team / contacts fields on `/admin/compliance`. Starting

the register is NPC task `t3-15` (seeded not started). Until then, keep the § 10.2 template as a dated file.

8.2 Annual report to the NPC

Setnayan submits an **annual report of the summary of security incidents and personal data breaches** to the NPC in the form and period the NPC prescribes. The DPO compiles this from the breach register.

8.3 Retention

Breach-register entries and supporting evidence are retained consistent with the Privacy & Security Policy § 4 audit-log retention (**5 years**) and any longer period required for pending NPC or legal proceedings.

---

9. Post-Incident Review

After every notifiable breach (and periodically for aggregated non-notifiable incidents), the DBRT conducts a documented review covering:

- **Root-cause analysis** — the technical and organizational cause, and why existing controls did not prevent it.
- **Remediation** — permanent fixes, additional controls, and verification that they work.
- **Policy & control update** — amend this policy, the Privacy & Security Policy, RLS patterns, monitoring rules, access lists, or sub-processor terms as needed.
- **Awareness** — brief the team; update onboarding materials; schedule/refresh the annual drill.
- The DPO signs off the review; changes to this policy follow the review cadence in the header.

---

10. Incident Response Quick-Flow & Breach Register Template

10.1 Quick-flow (one page)

```
+-------------------------------------------------------------------------+
|  SETNAYAN INCIDENT RESPONSE — QUICK-FLOW                                |
|  (72-hour clock starts on KNOWLEDGE of a notifiable breach)             |
+-------------------------------------------------------------------------+
|                                                                         |
|  1. DETECT                                                              |
|     Sentry / Better Stack alert · user report (iscasasolaii@gmail.com) ·        |
|     sub-processor notice · internal discovery                           |
|         |  report to DPO + Ops Coordinator ≤ 1 hour                     |
|         v                                                               |
|  2. CONTAIN                                                             |
|     Isolate systems · revoke credentials/tokens/signed URLs · rotate keys ·|
|     lock affected accounts · engage sub-processor support               |
|     >> PRESERVE EVIDENCE (logs, audit trail, snapshots)                 |
|         v                                                               |
|  3. ASSESS  (DPO)                                                       |
|     Personal data involved?  --No--> log as security incident, monitor  |
|         | Yes                                                           |
|         v                                                               |
|     NOTIFIABILITY TEST — ALL three?                                     |
|       (1) personal data breach  AND                                     |
```

```
|       (2) SPI / face vectors OR identity-fraud-enabling data  AND          |
|       (3) real risk of serious harm                                        |
|         | No --> record in register + reasoning, monitor                    |
|         | Yes / Uncertain                                                   |
|         v                                                                  |
|  4. NOTIFY  ≤ 72 HOURS from knowledge                                      |
|     • NPC  — nature · data involved · measures taken · DPO contact         |
|     • Affected data subjects — in-app + email (Resend); what happened,     |
|       what we did, what they should do, DPO contact                        |
|     • (as appropriate) public notice at setnayan.com/security              |
|         v                                                                  |
|  5. REMEDIATE                                                              |
|     Eradicate root cause · recover (NO DB BACKUPS — see § 7.1) · verify            |
|     integrity vs audit log · heightened monitoring                         |
|         v                                                                  |
|  6. REVIEW                                                                 |
|     Root-cause · remediation · update policy/controls · record in register |
|     · feed the annual NPC summary report                                   |
|                                                                            |
+----------------------------------------------------------------------------+
```

10.2 Breach register template

#	Discovered	Occurred	Duration (Ack → Contained)	Data subjects affected (count + role)	Data affected (categories + records)	Notifiable? (Y/N + reason)	NPC notified (date/time)	Subjects notified (date/time)	Containment actions	DPO sign-off
2026-001	*(example row)*				Confidentiality — photos, signed-URL misconfiguration				Logging.	Open / Closed

Legend — breach type: A = Availability · I = Integrity · C = Confidentiality. **Notifiable?** applies the § 5.2 three-part test; record the reason in either direction.

---

11. Effectivity & Approval

This policy takes effect on **‹OWNER TO SUPPLY: adoption date›** and remains in force until superseded. It is reviewed at least annually and after any notifiable breach (§ 9). Per the adoption posture above, effectivity requires completion of the owner-supplied fields and the DPO's sign-off; external PH counsel review is **recommended and applied by a dated amendment, not a precondition**.

Approver	Name	Signature	Date
Version	**v1.1 — revised 2026-10-22**		
Personal Information Controller (Proprietor)	Indalecio Sacdalan Casasola II · SETNAYAN SOFTWARE DEVELOPMENT SERVICE		

Data Protection Officer	Indalecio Sacdalan Casasola II

Appendix — Cross-references

- **Setnayan Privacy & Security Policy** — § 5 (access control & audit log), § 7 (security practices), § 8 (breach notification), § 10 (sub-processors & cross-border transfers).
- **NPC Circular 16-03** — Personal Data Breach Management (governing circular for this policy).
- **RA 10173** §§ 20, 26–31 and IRR Rules VIII–IX.
- **0028 Email Notifications** — `security_alert` template used for data-subject notification via Resend.
- **0023 Admin Console** — append-only audit log and role-based access supporting detection and evidence.

Compliant baseline; not a substitute for legal review. This policy is adopted by the DPO (Indalecio Sacdalan Casasola II); external PH counsel review is recommended and applied by a dated amendment, not a precondition to effectivity. The "public summary within 7 days where appropriate" (§ 6.2) is a breach public-disclosure timing and is unrelated to the 15-business-day data-subject-request SLA.